Reset Password API

Doova One View · Authentication Module

This document covers the two-step password reset flow: first the user requests a one-time code sent to their email, then they submit that code along with their new password to complete the reset.

How It Works

The flow has exactly two steps:

1. User enters their email on the "Forgot Password" screen.
2. The API sends a 6-digit OTP to that email (valid for 10 minutes).
3. User enters the OTP and their new password on the next screen.
4. The API verifies the OTP and updates the password.

> ***Security note:*** *Both endpoints always return a generic success message — even when the email does not exist — so attackers cannot use them to check whether an account is registered.*

Step 1 — Request a Reset Code

POST	`/auth/forgot-password`	*Sends a 6-digit OTP to the user's email*

Request body

Field	Type	Required	Notes
`email`	string	Yes	Must be a valid email address

Example request

```
POST /auth/forgot-password
Content-Type: application/json

{
  "email": "user@example.com"
}
```

Responses

HTTP Code	Meaning	Body

200	Success (always returned)	`{"message": "If that email exists, a reset code has been sent.", "message_type": "success"}`
400	Server failed to send the email	`{"detail": "Failed to send reset email. Please try again later."}`
422	Validation error (bad format)	`{"detail": [...]}`

Step 2 — Reset the Password

POST `/auth/reset-password` *Verifies the OTP and sets the new password*

Request body

Field	Type	Required	Notes
`email`	string	Yes	Same email used in Step 1
`otp`	string	Yes	Exactly 6 digits received by email. Expires after 10 minutes.
`new_password`	string	Yes	Minimum 8 characters
`new_password_confirm`	string	Yes	Must match new_password exactly

Example request

```
POST /auth/reset-password
Content-Type: application/json
{
  "email": "user@example.com",
  "otp": "482910",
  "new_password": "MyNewPass123",
  "new_password_confirm": "MyNewPass123"
}
```

Responses

HTTP Code	Meaning	Body
200	Password reset successfully	`{"message": "Password reset successfully", "message_type": "success"}`
400	Invalid/expired OTP or passwords mismatch	`{"detail": "Invalid or expired reset code"}`
422	Validation error (missing fields)	`{"detail": [...]}`

Common Mistakes to Avoid

x **OTP already used**	Each code is single-use. Once the password is reset, that OTP is invalidated immediately.
x **OTP expired**	The code is only valid for 10 minutes. If it expires, the user must go back to Step 1.
x **Requesting a new OTP**	Calling Step 1 again automatically cancels any previous unused OTP for that user.
x **Passwords do not match**	new_password and new_password_confirm must be identical, or you get a 400 error.
x **Wrong Content-Type**	Always send Content-Type: application/json or the server will reject the request.